

Genuine API defects

Every issue below was reproduced against SUT commit d97f995247a4a31ac91e8c6664da6fbf58b5fbd5 on 2026-08-08. Raw responses and assertion details are in `newman/results/*.json`, `/*.xml`, and the HTML reports.

BUG-API-001 – Login does not validate credential input domains

- Severity: Medium
- Evidence: LOGIN-002, 004-009, 012-017, 020, 021, 035, 036, 040
- Expected: malformed, missing, null, wrong-type, empty, and oversized credentials return 400.
- Actual: the endpoint treats them as authentication failures and returns 401.
- Impact: client defects and hostile input cannot be distinguished from valid authentication failures; required domain validation is absent.
- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/32>
- Screenshot:

Platform Solutions Resources Open Source Enterprise Pricing

Search Sign in Sign up

yuran1811 / hcmus-sw-testing--hw Public

Notifications Fork 0 Star 0

<> Code Issues 37 Pull requests Actions Projects Security and quality Insights

[HW06][BUG-API-001] Login does not validate credential input domains (returns 401 instead of 400) #32

Open

yuran1811 opened 1m ago Owner

Summary

The POST /api/login endpoint fails to perform domain validation on input parameters. Malformed, missing, null, wrong-type, empty, and oversized credentials are treated as invalid authentication credentials returning HTTP 401 Unauthorized instead of schema/domain validation failure HTTP 400 Bad Request.

Severity

Medium

SUT

POST /api/login (SUT commit d97f995247a4a31ac91e8c6664da6fbf58b5fbd5)

Evidence / Test Cases

LOGIN-002, LOGIN-004 - LOGIN-009, LOGIN-012 - LOGIN-017, LOGIN-020, LOGIN-021, LOGIN-035, LOGIN-036, LOGIN-040 in Newman execution suite (newman/results/login.json, newman/reports/login/index.html).

Expected

Malformed inputs (missing password/email, null fields, integer types, oversized strings, invalid formatting) should be rejected by request validation with HTTP 400 Bad Request before authentication lookup.

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

No branches or pull requests

Participants

Open in GitHub Copilot app

- Test failure evidence:

Iteration 2 - AssertionError - Pool A - Login - Execute Login Case

BUG-API-002 – Account locks after two failed attempts instead of three

- Severity: High
- Evidence: LOGIN-027; expected 200, observed 403 after exactly two pre-failures.
- Expected: the third failed attempt triggers lockout; a correct credential after two failures remains allowed.
- Actual: internal attempts increase by two per failure, so the second failure crosses the threshold.

- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/33>
- Screenshot:

Platform Solutions Resources Open Source Enterprise Pricing

Search Sign in Sign up

yuran1811 / hcmus-sw-testing--hw Public

Notifications Fork 0 Star 0

<> Code Issues 37 Pull requests Actions Projects Security and quality Insights

[HW06][BUG-API-002] Account locks after two failed attempts instead of three #33

New issue

Open

yuran1811 opened 1m ago Owner

Summary

The account lockout mechanism on `POST /api/login` locks an account after only two failed login attempts instead of the required three failed attempts.

Severity

High

SUT

`POST /api/login` (SUT commit `d97f995247a4a31ac91e8c6664da6fbf58b5fbd5`)

Evidence / Test Cases

`LOGIN-027` in Newman execution suite (`newman/results/login.json` , `newman/reports/login/index.html`).

Expected

Account lockout should trigger on the third failed attempt. Submitting a correct credential after two failed attempts must successfully authenticate (HTTP 200 OK).

Actual

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

No branches or pull requests

Participants

Open in GitHub Copilot app

- Test failure evidence:

Iteration 27 - AssertionError - Pool A - Login - Execute Login Case

BUG-API-003 – Login response exposes the plaintext password

- Severity: Critical
- Evidence: LOGIN-032 (body.user.password exists).
- Expected: credential material is never returned.
- Actual: the complete database user row, including password, is returned in the success body.
- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/34>

- Screenshot:

Platform Solutions Resources Open Source Enterprise Pricing

Search Sign in Sign up

yuran1811 / hcmus-sw-testing--hw Public

Notifications Fork 0 Star 0

<> Code Issues 37 Pull requests Actions Projects Security and quality Insights

[HW06][BUG-API-003] Login response exposes plaintext password in user object #34

New issue

Open

yuran1811 opened 1m ago Owner

Summary

A successful response from `POST /api/login` includes the user's plaintext password in the returned user object (`body.user.password`).

Severity

Critical (Security / CWE-200 / CWE-312)

SUT

`POST /api/login` (SUT commit `d97f995247a4a31ac91e8c6664da6fbf58b5fbd5`)

Evidence / Test Cases

`LOGIN-032` in Newman execution suite (`newman/results/login.json` , `newman/reports/login/index.html`).

Expected

Credential and secret material must never be returned in HTTP response bodies. The `user` object in the response should only include non-sensitive fields such as `id` , `email` , `role` , and `name` .

Actual

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

No branches or pull requests

Participants

Open in GitHub Copilot app

- Test failure evidence:

Iteration 32 - AssertionError - Pool A - Login - Execute Login Case

BUG-API-004 – Checkout accepts invalid totals and addresses

- Severity: Critical
- Evidence: CHECKOUT-004-015, 017-024, 030, 031, 038, 040.
- Expected: non-positive, non-integer, non-numeric, null/missing totals and invalid addresses return 400.
- Actual: orders are created with 200, including negative totals and absent addresses.
- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/35>

- Screenshot:

The screenshot shows a GitHub issue page for the repository `yuran1811/hcmus-sw-testing--hw`. The issue title is "[HW06][BUG-API-004] Checkout accepts invalid totals, negative amounts, and absent addresses #35". The issue is labeled as "Open" and "New issue". The issue was opened by `yuran1811` 1m ago. The issue summary states: "The `POST /api/checkout` endpoint does not validate order totals or shipping addresses. Orders can be successfully created with negative totals, decimal numbers, non-numeric values, or completely absent/empty address fields." The severity is "Critical (Business Logic / Data Integrity)". The SUT is "POST /api/checkout (SUT commit `d97f995247a4a31ac91e8c6664da6fbf58b5fbd5`)". The evidence/test cases are "CHECKOUT-004 - CHECKOUT-015, CHECKOUT-017 - CHECKOUT-024, CHECKOUT-030, CHECKOUT-031, CHECKOUT-038, CHECKOUT-040 in Newman execution suite (`newman/results/checkout.json`, `newman/reports/checkout/index.html`).". The expected behavior is "Non-positive, non-integer, non-numeric, null, or missing `total` fields and empty/missing `address` fields must be rejected with HTTP 400 Bad Request." The right sidebar shows "Assignees: No one assigned", "Labels: No labels", "Projects: No projects", "Milestone: No milestone", "Relationships: None yet", "Development: No branches or pull requests", and "Participants: Open in GitHub Copilot app".

- Test failure evidence:

The screenshot shows a test failure message from Newman. The message is "Failed Test: CHECKOUT-004 expected HTTP 400". The assertion error message is "expected response to have status code 400 but got 200".

BUG-API-005 – Checkout creates orders for an empty cart and trusts client totals

- Severity: Critical
- Evidence: CHECKOUT-036, CHECKOUT-037.
- Expected: empty-cart checkout is rejected and the server computes the total from server-side cart/product data.
- Actual: a caller can create an order with no cart and an arbitrary total such as 1.
- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/36>

- Screenshot:

The screenshot shows a GitHub issue page for the repository `yuran1811/hcmus-sw-testing--hw`. The issue title is "[HW06][BUG-API-005] Checkout creates orders for empty cart and trusts arbitrary client totals #36". It is labeled as a "New issue" and is currently "Open". The issue was opened by `yuran1811` 1m ago. The issue summary states: "The `POST /api/checkout` endpoint allows order creation when the user's cart is completely empty and blindly trusts client-provided total amounts rather than computing the total from server-side cart/product prices." The severity is "Critical (Business Logic / Financial Tampering)". The SUT is "POST /api/checkout (SUT commit `d97f995247a4a31ac91e8c6664da6fbf58b5fbd5`)". The evidence/test cases are "CHECKOUT-036, CHECKOUT-037 in Newman execution suite (`newman/results/checkout.json`, `newman/reports/checkout/index.html`)". The expected behavior is "Checking out with an empty cart should return HTTP 400 Bad Request. The server must compute the total price independently from server-side cart items and active product catalog pricing." The actual behavior is not specified. The right sidebar shows no assignees, labels, projects, milestones, relationships, development, or participants.

- Test failure evidence:

The screenshot shows a test failure message. The title is "Iteration 36 - AssertionError - Pool B - Checkout - Execute Checkout Case". The message is "Failed Test: CHECKOUT-036 expected HTTP 400". The assertion error message is "expected response to have status code 400 but got 200".

BUG-API-006 – Canceled order can transition to delivered

- Severity: High
- Evidence: ORDER-021; expected 400, observed 200.
- Expected: canceled is terminal.
- Actual: canceled → delivered is explicitly accepted.
- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/37>

- Screenshot:

The screenshot shows a GitHub issue page for the repository `yuran1811/hcmus-sw-testing--hw`. The issue title is "[HW06][BUG-API-006] Canceled order can transition to delivered status #37". The issue is labeled as "Open" and was opened 1m ago by user `yuran1811`. The issue summary states: "The order status update endpoint allows transitioning an order from `canceled` status directly to `delivered` status, violating terminal state invariants." The severity is "High (State Machine Integrity)". The SUT is `PUT /api/admin/orders/:id/status` (SUT commit `d97f995247a4a31ac91e8c6664da6fbf58b5fbd5`). The evidence/test cases section mentions "ORDER-021 in Newman execution suite (`newman/results/orderstatus.json` , `newman/reports/orderstatus/index.html`).". The expected behavior is that the `canceled` state is a terminal state and any attempt to transition out of it (e.g., `canceled -> delivered`) must be rejected with HTTP 400 Bad Request. The actual behavior is not specified. The right sidebar shows no assignees, labels, projects, milestones, relationships, development, or participants.

- Test failure evidence:

The screenshot shows a test failure message. The title is "Iteration 21 - AssertionError - Pool C - Admin Order Status - Execute Order Status Case". The message states: "Failed Test: ORDER-021 expected HTTP 400". Below this, the assertion error message is displayed: "expected response to have status code 400 but got 200".

BUG-API-007 – Admin order-state endpoint lacks role authorization

- Severity: Critical
- Evidence: ORDER-036, ORDER-037, ORDER-040.
- Expected: a normal-user token receives 403 before resource/state evaluation.
- Actual: a normal user can change pending orders (200), and receives state-based 400 for a delivered order, proving that role authorization is never enforced.
- GitHub issue: <https://github.com/yuran1811/hcmus-sw-testing--hw/issues/38>

- Screenshot:

Platform

Solutions

Resources

Open Source

Enterprise

Pricing

Search

Sign in

Sign up

yuran1811 / hcmus-sw-testing--hw

Public

Notifications

Fork 0

Star 0

<> Code

Issues 37

Pull requests

Actions

Projects

Security and quality

Insights

[HW06][BUG-API-007] Admin order status endpoint lacks role authorization #38

New issue

Open

yuran1811 opened 1m ago

Owner

Summary

The `PUT /api/admin/orders/:id/status` route does not enforce admin role authorization. Non-admin standard authenticated users can invoke this endpoint to mutate order statuses.

Severity

Critical (Broken Access Control / Privilege Escalation / CWE-285)

SUT

`PUT /api/admin/orders/:id/status` (SUT commit `d97f995247a4a31ac91e8c6664da6fbf58b5fbd5`)

Evidence / Test Cases

`ORDER-036`, `ORDER-037`, `ORDER-040` in Newman execution suite (`newman/results/orderstatus.json`, `newman/reports/orderstatus/index.html`).

Expected

A normal user token without admin privileges must receive HTTP 403 Forbidden immediately, prior to checking order existence or transition validity.

Actual

Assignees

No one assigned

Labels

No labels

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

No branches or pull requests

Participants

Open in GitHub Copilot app

- Test failure evidence:

Iteration 36 - AssertionError - Pool C - Admin Order Status - Execute Order Status Case

Failed Test: ORDER-036 expected HTTP 403

ASSERTION ERROR MESSAGE

expected response to have status code 403 but got 200